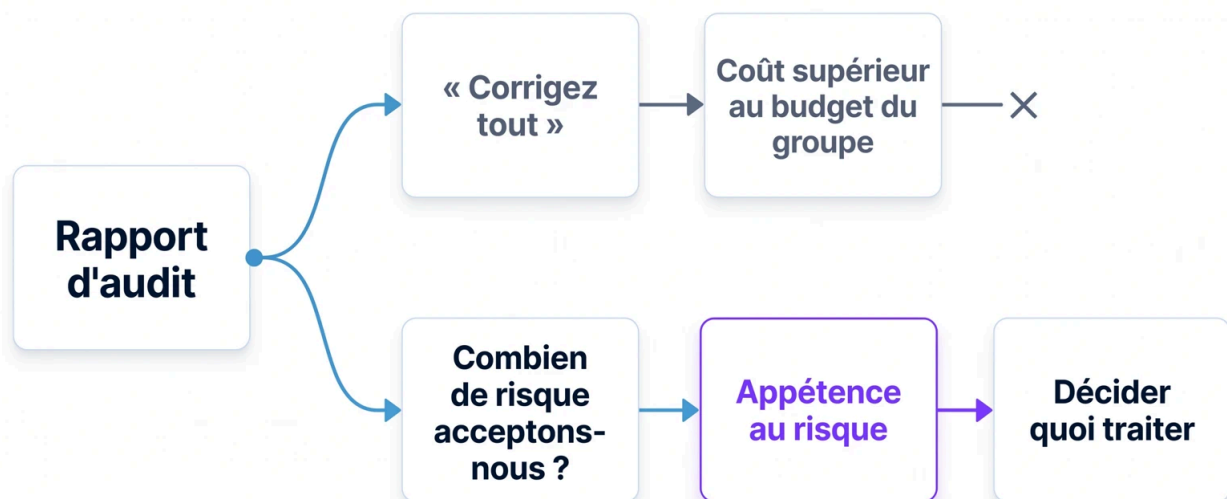


Le point du RSSI : Appétence au risque

✓ La question qui précède toutes les mesures



Objectifs de la séance

À l'issue de cette séquence :

- **Définir** l'appétence au risque et la distinguer de la tolérance au risque et de la ligne d'acceptation
- **Formuler** un énoncé d'appétence utilisable par une direction générale : testable, daté, porté par la bonne instance
- **Appliquer** la gouvernance de l'appétence posée en séance 1 au groupe MERIDIAN : qui fixe, qui approuve, qui décline, et ce que le RSSI fait vraiment

- **Confronter** les constats du rapport d'audit de la séance 4 à une appétence proposée, et en tirer des décisions immédiates
- **Analyser** une décision réelle de direction face à une cyberattaque en termes d'appétence et de tolérance

Prérequis

- La gouvernance posée en séance 1 : la Direction Générale fixe l'appétence au risque, le Conseil d'Administration l'approuve, le Comité de Direction valide sa déclinaison opérationnelle et budgétaire, et le RSSI Groupe élabore la PSSI (politique de sécurité des systèmes d'information) et arbitre les conflits inter-filiales.
- Le rapport d'audit produit en séance 4, avec ses écarts qualifiés par filiale : c'est lui qui rend la question de ce matin urgente.
- La cartographie de la séance 2 : valeurs métier, biens supports et besoins DICT (disponibilité, intégrité, confidentialité, traçabilité), dont le Top 5 des actifs critiques.

Ce qu'il faut savoir avant l'exercice

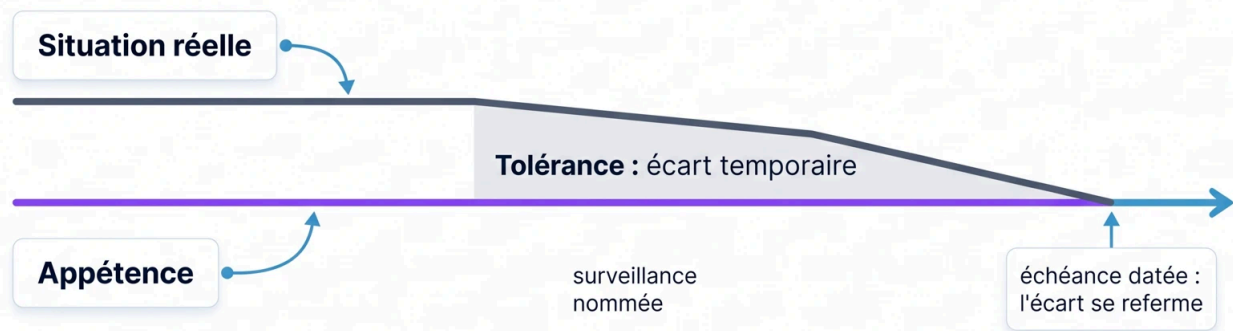
Le rapport d'audit de la semaine dernière a mis des écarts noir sur blanc. La réaction naturelle d'une direction qui le lit est de demander : « corrigez tout ». Celle du RSSI doit être différente, et c'est tout l'objet de ce point du RSSI : tout corriger coûte plus que le budget du groupe, et tout ne mérite pas d'être corrigé. Avant de décider quoi traiter, il faut savoir combien de risque le groupe accepte de porter. Cette quantité a un nom.

L'appétence au risque est définie par le guide publié conjointement par l'ANSSI (Agence nationale de la sécurité des systèmes d'information) et l'AMRAE (Association pour le management des risques et des assurances de l'entreprise) en 2019, « Maîtrise du risque numérique - l'atout confiance » : « L'appétence aux risques est le niveau de risque qu'un dirigeant accepte de prendre pour soutenir les activités et le développement de son organisation. Elle appuie les décisions stratégiques et oriente les opérations. » Les deux moitiés de la phrase sont à retenir. La première dit qu'accepter du risque n'est pas une faiblesse : c'est un choix de dirigeant, assumé pour que l'activité vive. Une entreprise à appétence nulle n'ouvre ni site web, ni entrepôt, ni service en ligne. La seconde moitié dit à quoi sert l'appétence : à décider. Un énoncé d'appétence qui ne permet de trancher aucune décision concrète est un vœu, pas un outil.

Le même guide précise le lien avec la notion voisine : « l'appétence aux risques définit le seuil d'acceptation des risques de l'organisation ». **La ligne d'acceptation** est donc la traduction opérationnelle de l'appétence : la ligne au-dessus de laquelle un risque identifié n'est plus acceptable en l'état et appelle une décision de traitement. L'appétence est une orientation de direction, le seuil est la règle qu'on en déduit pour instruire chaque risque, un par un. La fin de journée montrera que ce seuil se dessine concrètement sur une grille de cotation ; ce matin, ce qui compte est de savoir qui le pose et pourquoi.

Reste **la tolérance au risque**, que le vocabulaire professionnel distingue de l'appétence sans qu'un texte officiel du corpus de la formation la définisse : elle est donc définie ici pour le module. La tolérance est l'écart temporaire que l'organisation accepte entre son appétence et sa situation réelle, avec un suivi et une échéance. TRAMONTANE, l'enseigne fictive de vente en ligne d'équipement de plein air qui sert d'exemple au module, peut avoir une

appétence très faible pour l'indisponibilité de son site marchand et tolérer pourtant, pendant six mois et sous surveillance, un écart connu sur le logiciel de son entrepôt de Rivesaltes, parce que le corriger prend six mois. La tolérance n'est pas une appétence déguisée : elle est datée, suivie, et elle se referme.



Notion	Ce que c'est	Qui la porte	Sa marque de fabrique
Appétence au risque	Le niveau de risque accepté pour soutenir l'activité	La direction générale, approuvée par l'organe de gouvernance	Stratégique, stable, oriente toutes les décisions
Seuil d'acceptabilité	La ligne au-dessus de laquelle un risque appelle un traitement	Déduit de l'appétence, appliqué par le management du risque	Opérationnel, s'applique risque par risque
Tolérance au risque	L'écart temporaire accepté entre l'appétence et le réel	Décidée au cas par cas, avec suivi	Datée, surveillée, se referme

Ce tableau est le filet de sécurité de l'exercice : quand une phrase entendue en comité mélange les trois notions, c'est presque toujours qu'elle fait passer une tolérance non datée pour de l'appétence, et c'est exactement le genre de glissement qu'un RSSI doit attraper au vol.

Un cas réel pour ancrer tout cela. En 2019, l'aluminier norvégien Norsk Hydro subit un rançongiciel qui paralyse une partie de ses usines. La direction refuse de payer la rançon, bascule la production en mode manuel et communique publiquement, jour après jour, sur l'état de ses systèmes. Norsk Hydro a estimé l'impact financier de la cyberattaque entre 250 et 300 millions de couronnes norvégiennes sur le deuxième trimestre 2019. Cette décision

se lit avec les trois notions posées : la direction avait une appétence nulle pour le financement d'un groupe criminel et pour la perte de contrôle de ses données, et une appétence assumée pour un coût opérationnel énorme mais borné. Elle a préféré un impact financier lourd et mesurable à un précédent qu'elle jugeait inacceptable. C'est cela, une appétence qui fonctionne : elle était connue avant la crise, et elle a permis de décider vite pendant.

💡 Réflexe de méthode : une appétence s'énonce toujours par rapport à quelque chose qu'on accepte de perdre ou de dégrader, jamais dans l'absolu. « Nous sommes prudents » n'engage rien. « Nous acceptons de retarder une livraison, jamais d'exposer un dossier patient » engage tout.

✓ Cas pratique : faire fixer l'appétence du groupe MERIDIAN

Mise en situation et énoncé

Mardi, 17 h 30. La Directrice Générale du groupe MERIDIAN sort de la présentation du rapport d'audit et retient le RSSI Groupe : « Votre rapport dit que la Logistique fait tourner ses réseaux industriels et bureautiques ensemble, et que la Santé a des mots de passe sans double vérification. Le Directeur de la filiale Logistique me dit qu'on ne touche pas aux automates en période de pointe, et que la pointe dure dix mois sur douze. Le Directeur médical de la Santé me dit qu'une authentification supplémentaire sur un poste de soins, c'est du temps pris au patient. L'Audit Interne me dit que la Santé n'a toujours pas remis son registre des comptes d'administration, et qu'on joue avec des données de patients. Ils ont tous raison, et je ne vais pas trancher trente fois par an. Donnez-moi de quoi poser une règle une bonne fois : ce que le groupe accepte, ce qu'il n'accepte pas. Je veux votre proposition jeudi, je la porterai au Conseil d'Administration. »

Le RSSI Groupe dispose du rapport d'audit de la séance 4, dont les écarts qualifiés par filiale : mots de passe locaux sans MFA (authentification multifacteur) côté Santé, réseaux IT (informatique de gestion) et OT (informatique industrielle) interconnectés côté Logistique, comptes d'administration partagés côté Éducation, journaux conservés localement côté Territoires. S'y ajoutent la cartographie et le Top 5 des actifs critiques de la séance 2, et la gouvernance posée en séance 1.

Le travail de ce matin : préparer la proposition d'appétence que la Direction Générale fixera, dans les formes que la gouvernance du groupe impose.

Questions guidées

1. **Classer** les trois phrases suivantes, entendues au dernier Comité de Direction, selon qu'elles expriment une appétence, une tolérance ou une ligne d'acceptation, en justifiant en une phrase chacune : « Aucun projet ne

sera bloqué plus de 48 heures pour une revue sécurité » ; « On garde l'interconnexion IT/OT jusqu'à la prochaine fenêtre hors pointe, avec une surveillance renforcée, et on revoit ça au prochain trimestre » ; « Tout risque coté au-delà du niveau élevé sur notre future grille devra être traité avant mise en production ».

2. **Rédiger** deux énoncés d'appétence : un premier sur le bien à protéger de la filiale instruite, c'est-à-dire celle dont le groupe tient le dossier, tel que le §2 du dossier de filiale le nomme ; un second transverse au groupe, valable pour les quatre filiales. Contrainte : chaque énoncé doit permettre de trancher au moins une décision concrète que le groupe a réellement devant lui, en indiquant laquelle.
3. **Confronter** chacun des quatre écarts d'audit aux énoncés rédigés et à l'esprit de l'appétence proposée : lesquels sont clairement au-dessus de la ligne, lesquels relèvent d'une tolérance à formaliser, et que manque-t-il à chaque tolérance pour en être une ?
4. **Attribuer** les rôles pour jeudi : qui fixe l'appétence, qui l'approuve, qui valide sa déclinaison budgétaire, et qu'est-ce qui reste exactement dans les mains du RSSI Groupe ? Identifier le piège de posture qui guette le RSSI dans la phrase de la Directrice Générale.
5. **Analyser** la décision de Norsk Hydro en 2019 avec le vocabulaire du matin : formuler en deux phrases l'appétence implicite que révèle le refus de payer, et ce que cette décision aurait eu de différent si elle avait dû s'improviser sans appétence préalable.

Méthode de travail

Traiter les questions dans l'ordre : la question 1 vérifie les définitions, les questions 2 et 3 construisent la proposition, les questions 4 et 5 la mettent en perspective. Pour les énoncés de la question 2, appliquer le test du tableau : un énoncé d'appétence qui ne fait ni gagner ni perdre une décision réelle est à réécrire. Compter 10 minutes pour la question 1, 15 minutes pour les questions 2 et 3, et 5 minutes pour les deux dernières.



Corrigés et critères d'évaluation – cliquer pour révéler